KEAMANAN SIBER

KELAS A – KELOMPOK 5

PROGRES PBL FASE 1 - 2

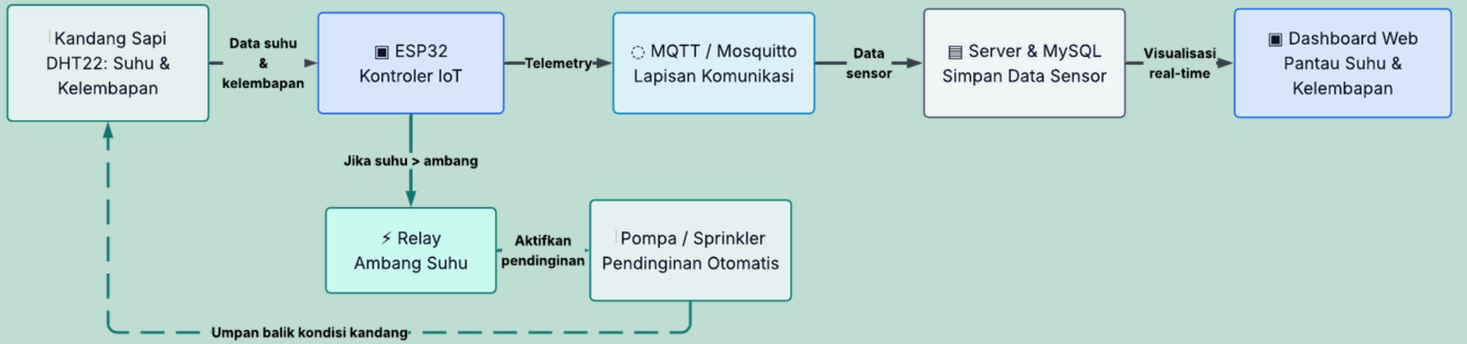
Fattih Algie Maulana (J0404241002)

Al Fariz Muhammad Zibril (J0404241036)

Syamil Abdillah (J0404241139)

Ratu Festiza Alya Ichsan (J0404241174)

Konteks Proyek IoT

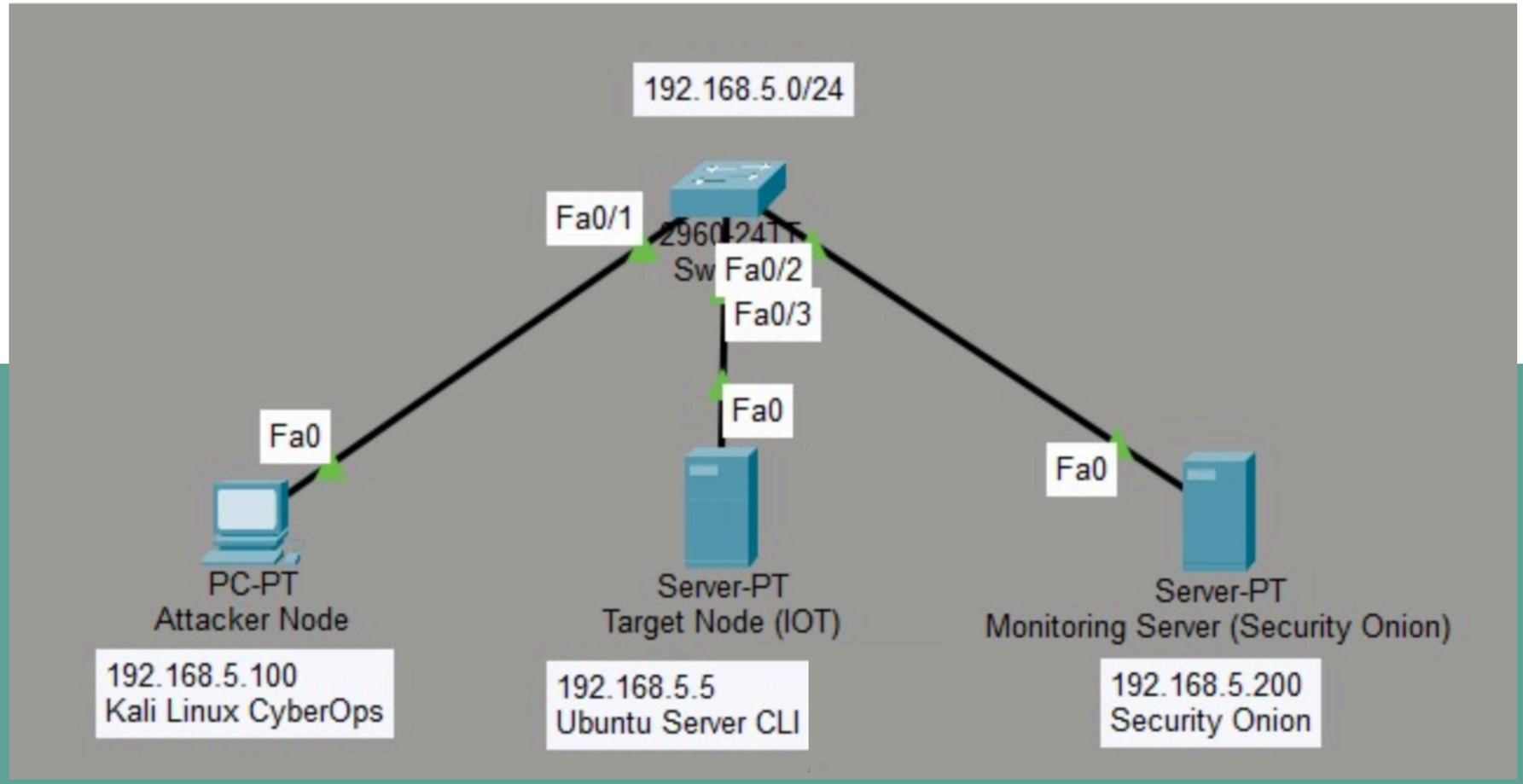


Setiap komponen yang saling terhubung memiliki potensi risiko keamanan. Oleh karena itu, sistem direplikasi sebagai target pengujian untuk mengevaluasi konfigurasi keamanan dan aktivitas jaringan melalui monitoring.

Deklarasi Tech Stack & Replikasi

Komponen	Proyek asli	Replika (Target Node)
Backend	Tidak ada server sendiri, sepenuhnya cloud Firebase paket Spark, dipakai dari komputer lokal	Ubuntu Server 26.04 LTS, VM UBUNTU SYAMIL, 192.168.5.5
Database	Firebase Realtime Database, NoSQL, format JSON	MySQL 8.4 relasional, basis data iot_db, hanya loopback
Jalur data sensor	ESP32 baca DHT22 dan DS18B20, kirim ke Firebase lewat HTTPS REST di atas WiFi	MQTT 1883 topik sensors/#, plus HTTP REST dashboard
Dashboard	Dashboard web berbasis Firebase, data suhu dan kelembapan realtime	Dashboard Flask 3000, pantauan lewat Security Onion 192.168.5.200

Arsitektur Simulasi



Progres Hardening

Kategori	Kontrol	Status
A. Access dan Authentication	A1. SSH hanya menerima kunci publik, login root dilarang, MaxAuthTries 3	Selesai
A. Access dan Authentication	A2. Akun dan hak sudo dirapikan, direktori home 700, akun root terkunci	Selesai
A. Access dan Authentication	A3. fail2ban jail sshd, maxretry 3, bantime 1800 detik	Selesai
B. Service dan Attack Surface	B1. Layanan tidak terpakai dimatikan, apache berhenti, port 80 tertutup	Selesai
B. Service dan Attack Surface	B2. ufw whitelist, hanya port 22, 1883, dan 3000 dari jaringan lab	Selesai
B. Service dan Attack Surface	B3. Patch sistem, paket menunggu pembaruan dari 26 menjadi 0	Selesai
C. Data dan Application	C1. MySQL hanya mendengar di loopback	Selesai
C. Data dan Application	C2. Least privilege user basis data, akun default webapp dihapus	Selesai
C. Data dan Application	C3. Kredensial di berkas env dengan izin 600, tidak hardcoded	Selesai
C. Data dan Application	C4. Logging aktivitas dikirim ke Security Onion	Selesai
C. Data dan Application	C5. Validasi input pada endpoint dashboard dan topik MQTT	Belum
C. Data dan Application	C6. Autentikasi broker MQTT, akses anonim dimatikan	Belum

Baseline Traffic

Port atau ukuran	Layanan	Sebelum 18 Oktober	Sesudah 19 Oktober	Keterangan
22	SSH OpenSSH 10.2p1	terbuka	terbuka	tidak muncul pada pemindaian seluruh port karena pemindai terblokir fail2ban
80	HTTP Apache 2.4.66	terbuka	tersaring	layanan dimatikan, port ditutup ufw
1883	MQTT	terbuka	terbuka	dibiarkan untuk pengujian Fase 2
3000	HTTP Werkzeug 3.1.5	terbuka	terbuka	dashboard replika, sasaran uji injeksi
3306	MySQL 8.4.11	terbuka	tersaring	hanya mendengar di loopback, kontrol C1
9090	tidak dipakai	tertutup	tersaring	layanan tidak pernah dipakai
Jumlah port terbuka		5	2	
Port tersaring		0	65.533	
Port tertutup		65.530	0	
Durasi pemindaian seluruh port		20,52 detik	780,26 detik	naik karena paket dibuang, bukan ditolak

Live Demo Singkat >>

Attack Plan Fase 2

1. Reconnaissance **Pemetaan layanan**	2. Metode Dua **Pengujian autentikasi**	3. Web & IoT **Pengujian data dan protokol**
• Tools: Nmap, Wireshark • Uji: Port scanning, OS fingerprinting, banner/version detection. • Target: Port 22, 1883, 3000. • Deteksi Blue: SYN berulang ke port tersaring, pemindai berpotensi terblokir fail2ban	• Tools: Nmap NSE, Hydra • Uji: Pengujian kredensial pada SSH, percobaan enumerasi layanan basis data • Target: Port 22, sedangkan port 3306 tersaring dan hanya mendengar di loopback • Deteksi Blue: Login gagal berulang pada auth.log, pemblokiran fail2ban setelah tiga percobaan	• Tools: OWASP ZAP, Burp Suite, mosquitto_sub • Uji: SQL injection pada parameter device di dashboard, akses topik MQTT tanpa izin • Target: Dashboard port 3000 dan MQTT port 1883 • Deteksi Blue: Pola query mencurigakan pada log dashboard, sambungan MQTT anonim dari klien baru

Kendala & Pembelajaran

Kendala	Penanganan
Antarmuka Security Onion sangat lambat	Pengamatan dilakukan melalui tcpdump dan antarmuka baris perintah, antarmuka grafis hanya dibuka saat diperlukan
Penyimpanan tidak memadai sehingga mesin virtual galat dan tertutup paksa	Pembersihan cache dan mesin virtual tidak terpakai, serta pengoperasian mesin virtual secara bergiliran
Alamat IP harus dikonfigurasi ulang setiap kali booting	Konfigurasi dibuat permanen melalui netplan, profil koneksi, dan berkas antarmuka jaringan
Tangkapan layar kondisi sebelum hardening terlambat diambil	Kondisi awal direkonstruksi dari keluaran perintah yang tersimpan dan berkas pemindaian awal, kekurangannya dicatat
Log tidak sampai ke Security Onion	Aturan izin port 514 ditambahkan pada mesin penerima, bukan pada mesin pengirim
Pemblokiran fail2ban mengenai mesin penguji	Pemblokiran dibuka dari Target Node dan kejadian dicatat sebagai temuan

Terima Kasih